Redes de Computadores e Cibersegurança

Plano de Gerenciamento de Riscos

Motion Tennis

08/11/2026 – 2.0V

Arthur Rodrigues Ferreira – 24026567
Felipe Oluwaseun Santos Ojo – 24026245
Gabriel Henrique Coelho Marussi – 24026609
Nicolas Roberto Jordan Morales – 24025897

SP – 2026

1. Introdução

Este plano reúne como nós, do grupo do Motion Tennis, vamos identificar, avaliar, responder e acompanhar os riscos de cibersegurança e IoT do projeto. Ele complementa o plano geral de gerenciamento de riscos e olha só para a parte que mais nos preocupa em Redes e Cibersegurança.

O escopo é o que a nossa apresentação descreve: três sensores acústicos que captam o som do impacto da bola, o processamento que sincroniza os sinais e estima a posição, a comunicação pela rede até a API, a tela dedicada com o feedback em tempo real e a plataforma digital usada pelos clientes B2C. A antiga máquina lançadora mecânica ficou fora deste recorte.

Nosso objetivo é proteger a confidencialidade, a integridade e a disponibilidade dos dados e garantir que as medições continuem confiáveis. A precisão da localização do impacto é justamente o que vamos validar no protótipo e no piloto, então uma medição falsificada ou perdida atinge o centro da proposta.

2. Metodologia

Trabalhamos com análise qualitativa, priorizamos pela matriz acadêmica e revisamos as respostas a cada ciclo de desenvolvimento.

- **Identificação de riscos:** revisamos a arquitetura e o fluxo de dados, o código e as dependências, os relatórios do Aikido, a configuração de rede, os sensores e o firmware, os requisitos de privacidade e o histórico de incidentes. Também olhamos para o modelo de negócio, porque estações em estabelecimentos parceiros e assinaturas B2C aumentam a superfície de ataque e os dados tratados.
- **Análise de riscos:** estimamos probabilidade e impacto pelas escalas deste plano. Tratamos os achados do scanner como sinal para triagem, não como prova de exploração. Registramos a incerteza e reavaliamos depois da validação manual.
- **Planejamento de respostas:** para ameaças, escolhemos entre prevenir, mitigar, transferir ou aceitar. Para oportunidades confirmadas, entre explorar, melhorar, compartilhar ou aceitar.
- **Monitoramento e controle:** atualizamos o registro toda semana e sempre que surgir um achado crítico ou alto, uma mudança de arquitetura ou um release. Só damos o risco por tratado quando temos evidência da correção e sabemos qual risco residual sobrou.

3. Papéis e Responsabilidades

Papel	Responsabilidades no gerenciamento de riscos
Gerente de Projeto	Mantém o registro, convoca a revisão semanal, acompanha prazos e leva os riscos extremos e altos ao professor orientador.
Equipe do Projeto	Somos nós. Dividimos por área: quem cuida da API e do QA valida código e testes; quem cuida de IoT fica com firmware, sensores e rede; quem cuida da tela e da plataforma aplica controle de acesso e privacidade.
Patrocinador do Projeto	O professor orientador dá direção, valida recursos e decide sobre a aceitação de riscos residuais que passem do que a equipe pode assumir.
Partes Interessadas	Nós, o professor, o estabelecimento parceiro do piloto e os usuários de teste. Informam requisitos, dados tratados, impactos e evidências.

4. Orçamento e Cronograma para Gerenciamento de Riscos

A apresentação prevê R$ 2.000 para o MVP e o primeiro piloto (protótipo, plataforma inicial, tutoriais e testes em local parceiro). Partindo desse valor, e seguindo a mesma premissa simulada do plano geral, separamos 15% dele, ou seja, R$ 300,00, para riscos de cibersegurança e IoT. É a mesma reserva do plano geral; a tabela abaixo mostra como pretendemos distribuí-la. Todos os números são estimativas nossas para o contexto acadêmico.

Item	Estimativa	Para que serve
Reposição de hardware IoT	R$ 150,00	Sensor, ESP32, cabos ou fonte que queimem, sejam adulterados ou precisem ser trocados para manter os três pontos de captação.
Segurança e infraestrutura	R$ 100,00	Domínio e certificado TLS do ambiente de teste, armazenamento de segredos, backup e plano pago da ferramenta de varredura, se o gratuito não cobrir o escopo.
Imprevistos	R$ 50,00	Ajustes que não caibam nas duas linhas anteriores, usados só depois de aprovação em reunião.
Total da reserva	R$ 300,00	15% dos R$ 2.000 previstos para o MVP e o primeiro piloto.
Esforço da equipe	Cerca de 12 h por semana no grupo	Cerca de 3 h por integrante para triagem, correção, testes e a reunião semanal de riscos.

Para a operação depois do piloto, a apresentação estima R$ 250 por mês e por estação com suporte, conectividade e manutenção. Calculamos que cerca de R$ 40 desse valor (16%) precisem ir para monitoramento de segurança, renovação de certificados e backups. Essa parcela entra na validação com cotações e piloto.

- **Identificação inicial:** 08/11/2026, revalidada depois da primeira triagem técnica.
- **Reunião de riscos:** toda semana e, fora de hora, quando aparecer achado crítico ou alto ou uma mudança relevante.
- **Revisão deste plano:** a cada marco, sprint e release, reavaliando probabilidade, impacto e risco residual depois das respostas.
- **Ligação com o roadmap da apresentação:** concentramos a triagem do Aikido e o reforço da rede e dos sensores na etapa Integrar. Em Testar usuários e Pilotar, o foco passa a ser privacidade, rede do parceiro e disponibilidade. Só avançamos para Contratar e Replicar com os riscos extremos e altos tratados.

5. Categorias de Riscos

Seguimos a estrutura acadêmica e acrescentamos subcategorias que fazem sentido para um sistema IoT:

- **Técnicos:** software e API; processamento de sinais; rede e comunicação; hardware, sensores e firmware; identidade, dados e privacidade.
- **Gerenciais:** planejamento das correções, disponibilidade de quem responde, priorização, prazos e verificação das evidências.
- **Organizacionais:** governança de acesso, separação de ambientes, gestão de mudanças, inventário, registro de evidências e critérios de aceite.
- **Externos:** vulnerabilidades em dependências e serviços de terceiros, queda de rede ou de provedor, a rede e a infraestrutura do estabelecimento parceiro, mudanças regulatórias (como a LGPD) e ameaças externas.

6. Definições de Probabilidade e Impacto

A probabilidade é a nossa estimativa inicial de que o cenário aconteça. Não é uma medição estatística nem a chance de um achado ser explorado. Usamos as faixas abaixo e registramos a incerteza quando faltam detalhes técnicos.

Nível	Descrição	Valor
Muito Alta	Quase certo de ocorrer	> 80%
Alta	Provável de ocorrer	61% - 80%
Média	Pode ocorrer	41% - 60%
Baixa	Improvável de ocorrer	21% - 40%
Muito Baixa	Muito improvável de ocorrer	≤ 20%

No impacto, consideramos a maior consequência plausível para confidencialidade, integridade e disponibilidade, dados de usuários, resultados de impacto, operação da API e da tela e objetivos da entrega. Mantivemos as faixas de custo do modelo acadêmico como referência complementar.

Nível	Descrição
Muito Alto	Comprometimento amplo de dados ou do serviço, ou falha do objetivo principal; referência de custo: >20%.
Alto	Afeta a API, a tela ou vários usuários e sessões; referência de custo: 10% a 20%.
Médio	Interrupção ou distorção localizada e recuperável; referência de custo: 5% a 10%.
Baixo	Efeito breve em um sensor ou sessão, sem exposição relevante; referência de custo: 1% a 5%.
Muito Baixo	Efeito desprezível, corrigido na rotina; referência de custo: <1%.

7. Matriz de Probabilidade e Impacto

Aplicamos a matriz do modelo acadêmico sem alterações. A prioridade que sai dela indica o tratamento mínimo e a urgência do acompanhamento.

Probabilidade / Impacto	Muito Baixo	Baixo	Médio	Alto	Muito Alto
Muito Alta	Médio	Alto	Alto	Extremo	Extremo
Alta	Baixo	Médio	Alto	Alto	Extremo
Média	Baixo	Médio	Médio	Alto	Alto
Baixa	Muito Baixo	Baixo	Baixo	Médio	Médio
Muito Baixa	Muito Baixo	Muito Baixo	Baixo	Baixo	Médio

- **Extremo/Alto:** ação imediata, responsável definido, prazo ligado ao próximo release e evidência de validação antes do aceite.
- **Médio:** plano de mitigação e acompanhamento periódico. Só aceitamos com justificativa e responsável.
- **Baixo/Muito Baixo:** acompanhamento de rotina, com reavaliação se mudar a exposição, a arquitetura ou o contexto.

7.1. Registro de riscos de cibersegurança e IoT

A avaliação inicial combina a evidência do Aikido com cenários plausíveis da nossa arquitetura e do modelo de negócio. A probabilidade indica a chance estimada do evento, não de uma exploração comprovada. Vamos reavaliar depois da triagem técnica.

ID e categoria	Descrição do risco	Probabilidade	Impacto	Prioridade
TEC-SEC-01 Técnico - Software / análise por IA	Achados abertos de código	Alta	Muito Alto	Extremo
TEC-SEC-02 Técnico - Software / SAST	Achados estáticos de alta severidade	Alta	Alto	Alto
TEC-SEC-03 Técnico - Gestão de segredos	Credenciais em histórico	Média	Alto	Alto
EXT-OSS-01 Externo - Cadeia de suprimentos	Dependências de código aberto	Média	Alto	Alto
TEC-IAM-01 Técnico - API / identidade	Autorização e acesso a dados	Média	Alto	Alto
TEC-NET-01 Técnico - Rede / comunicação	Integridade e disponibilidade dos eventos	Média	Alto	Alto
TEC-IOT-01 Técnico - Hardware / IoT	Falsificação ou adulteração de sensores	Média	Alto	Alto
GER-OPS-01 Gerencial / Organizacional - operação	Registro, backup e resposta a incidentes	Média	Alto	Alto
GER-COV-01 Gerencial / Organizacional - cobertura	Ativos e superfícies fora da validação	Alta	Alto	Alto
TEC-PRV-01 Técnico - Dados e privacidade	Dados de usuários B2C (cadastro, desempenho, assinatura) e LGPD	Média	Alto	Alto

ID e categoria	Descrição do risco	Probabilidade	Impacto	Prioridade
EXT-PAR-01 Externo - Rede do parceiro	Rede do estabelecimento parceiro instável ou compartilhada	Alta	Médio	Alto
TEC-MOB-01 Técnico - Aplicativo móvel	Achados móveis com vínculo a confirmar	Média	Médio	Médio

8. Tolerância ao Risco das Partes Interessadas

Nossa tolerância é baixa para exposição de dados, credenciais, alteração de resultados e acesso não autorizado à API ou aos sensores. Aceitamos uma indisponibilidade breve de um sensor ou um pequeno atraso, desde que a demonstração não seja comprometida, os dados possam ser recuperados e exista responsável e plano de contingência. Como o piloto acontece em um local parceiro, também toleramos muito pouco qualquer falha que exponha dados de clientes do estabelecimento. Pretendemos ratificar essa tolerância com o professor.

9. Formatos de Relatórios

- **Registro de Riscos:** mantemos este registro, ou uma planilha compartilhada, com ID, descrição, categoria, probabilidade, impacto, prioridade, responsável, resposta, prazo, status, evidência e risco residual.
- **Relatório de Status dos Riscos:** apresentamos toda semana os riscos extremos e altos, os novos achados do Aikido, os falsos positivos confirmados, as ações, as pendências e a decisão sobre riscos residuais.

10. Acompanhamento

Revisamos o processo a cada marco, sprint e release, e sempre que mudar o fluxo de dados, o firmware, a rede ou a API. Um risco só é encerrado com evidência de correção ou com uma justificativa aprovada. O registro e as lições aprendidas ficam sempre atualizados.

11. Base de evidências e limitações

O relatório Security Audit Report do Aikido de 08/11/2026, registra 7 dependências médias e 1 baixa, 16 segredos históricos baixos, 2 achados SAST altos e 1 baixo e 3 achados móveis médios.

O export AI Code Analysis Issues do Aikido Security de 08/11/2026, registra 21 achados abertos (3 críticos, 4 altos, 8 médios e 6 baixos), 49 subachados, 4 ignorados e nenhum resolvido. Os achados dessa amostra podem se sobrepor ao SAST, então não devemos somar os totais. O Aikido indica medidas ativas de TLS, criptografia em repouso, lockfiles e alertas, mas também marca como incompletos os controles de acesso, autenticação, rede, backup, logging e separação de ambientes. A pontuação de nuvem é N/A. Esses dados mostram o monitoramento da conta e não provam que os controles estejam no build do Motion Tennis.

Os valores de orçamento e esforço deste plano são estimativas nossas, calculadas a partir dos números da apresentação (MVP de R$ 2.000 e custo recorrente de R$ 250 por mês por estação). Precisam ser confirmados com cotações e com o piloto.

12. Aprovação

Nome	Cargo	Assinatura	Data
A designar pela equipe	Gerente do Projeto	Pendente	Pendente
Docente orientador	Patrocinador / Orientador	Pendente	Pendente